

ASSESSMENT METHODOLOGY

Technical Testing Approach — FABA Cybersecurity Assessment

Companion document to the Cybersecurity Assessment Report (v1.2, sanitized)



Related Report:	FABA Cybersecurity Assessment Report, v1.2
Prepared By:	Kyle Dwyer
Document Reference:	FABA-CSA-METH-2026-001
Date:	July 19, 2026
Classification:	Public — Published with Permission

1. Assessment Classification and Rules of Engagement

This engagement was scoped as an external, unauthenticated-to-low-privilege assessment (a hybrid of black-box and grey-box testing): reconnaissance and most testing was performed with no credentials, followed by limited testing from the perspective of a single, self-registered low-privilege account. No source code, infrastructure diagrams, or internal documentation were provided or reviewed.

1.1 Rules of Engagement

- Testing limited to publicly reachable endpoints and standard user-facing workflows
- No authentication bypass, privilege escalation, or exploitation of identified weaknesses beyond the minimum needed to confirm the observation
- No automated dynamic application security testing (DAST) or vulnerability scanners run against production infrastructure, to avoid availability impact
- No denial-of-service, brute-force, or credential-stuffing style testing against authentication endpoints
- Single test account created through the standard public registration flow; no test data submitted that could be mistaken for a real consumer or agent

1.2 Testing Standard Reference

Testing activities are mapped informally to relevant categories from the OWASP Web Security Testing Guide (WSTG) for structure and terminology consistency, without claiming full coverage of any WSTG category:

Assessment Phase	Aligned WSTG Category (informal reference)	Technique Class
Reconnaissance	WSTG-INFO (Information Gathering)	Passive crawling, fingerprinting
Documentation Review	WSTG-CONF / Privacy control mapping	Policy-to-behavior comparison
Authentication Testing	WSTG-ATHN, WSTG-IDNT	State-transition & workflow analysis
Form / Input Testing	WSTG-INPV	Boundary & context-aware payload testing
Configuration Testing	WSTG-CONF (transport & headers)	Response header & cookie analysis

2. Reconnaissance and Attack Surface Mapping

Attack surface mapping began with unauthenticated crawling of all reachable pages, followed by manual identification of distinct functional zones (informational content, lead-generation forms, authentication endpoints, and the realtor search/discovery interface).

2.1 Techniques Applied

- Manual site-tree enumeration via navigation, sitemap references, and linked resources
- HTTP response header review per endpoint to identify transport-layer configuration (redirect behavior, HSTS presence, cookie attributes)

- Passive technology and third-party service fingerprinting from response headers, cookie namespaces, and embedded resource origins (results generalized in the public report; not itemized here)
- Classification of each discovered endpoint by trust boundary: fully public, form-gated, or requiring authentication

This mapping step determines where deeper testing effort is justified. Endpoints that only render static informational content were deprioritized in favor of endpoints that accept user input or manage account state, since those carry materially higher risk.

3. Documentation and Control-Mapping Review

Privacy Policy and Terms of Service language were treated as a set of testable claims rather than read passively. Each data-handling statement was cross-referenced against observed technical behavior where verification was possible from the outside.

Example control-mapping approach

Policy claim: "Payment information is processed by third-party providers." Verification method: Inspect payment-related form fields and network requests during a simulated checkout flow for evidence of direct card-data collection versus redirection/tokenization via a third party. Result: Consistent with policy – no direct card-data fields observed.

Where a claim could not be verified externally (e.g., internal data retention practices, backend storage encryption), this was recorded as "unverifiable from external testing" rather than assumed compliant or non-compliant.

4. Authentication and Identity Testing

This phase received the most testing depth, driven by a risk-based judgment call made during reconnaissance: FABA's core product is a trust and verification layer over real estate professionals, which makes identity and account-state integrity the highest-value target on the platform — not just another feature to check off a generic list.

4.1 Techniques Applied

- Workflow state-transition mapping: documenting every state an account can occupy (unverified / pending / active / publicly listed) and the specific action that triggers each transition
- Verification-gate analysis: for each state transition, testing whether the platform actually enforces the precondition it implies (e.g., does "pending verification" block search visibility, or is it cosmetic?)
- Session issuance timing analysis: observing when a valid, usable session is granted relative to account confirmation steps
- Field-level mutability testing: systematically attempting to modify each profile field post-creation to determine which fields are re-validated versus freely editable
- Password-reset workflow analysis: reviewing the reset mechanism's structure and delivery channel for rate-limiting, lockout, and monitoring indicators, without performing high-volume or automated reset requests

4.2 What Was Deliberately Not Done

- No automated or high-volume account creation (to avoid platform abuse or data pollution)
- No attempt to access, modify, or view any other user's account or data
- No brute-forcing of the password-reset code space

This phase produced the assessment's highest-severity findings because the technique — mapping actual enforcement against implied enforcement — surfaced a gap between what the platform's UI/UX implies about verification and what is technically enforced server-side.

5. Input Validation and Injection Testing

Public-facing forms (contact, registration, search) were tested for both client-side validation behavior and resistance to injection-style input, using non-destructive, context-appropriate payload classes.

5.1 Techniques Applied

- Boundary and format testing on structured fields (email format enforcement, required-field enforcement) using a range of malformed inputs
- Context-aware script-injection testing: submitting a standard non-destructive script payload through free-text fields and inspecting the rendered DOM/response for unescaped reflection versus encoded output
- Response and confirmation-message analysis to distinguish client-side-only validation from server-side enforcement

Because backend administrative interfaces and downstream data processing (storage, admin-panel rendering, email templating) were out of scope and inaccessible, findings in this phase are explicitly scoped to what is observable from the public-facing request/response cycle. The report does not claim backend injection resistance beyond what was directly observed.

6. Configuration and Transport Security Testing

This phase evaluated browser-enforced security controls delivered via HTTP response headers and cookie attributes — controls that constrain what a malicious script or third party can do even if another control fails.

6.1 Techniques Applied

- Manual inspection of HTTP response headers across representative endpoints for HSTS, Content-Security-Policy, X-Frame-Options, and X-Content-Type-Options
- Cookie attribute inspection (Secure, HttpOnly, SameSite) via browser developer tools
- Cross-Origin Resource Sharing (CORS) policy testing by observing Access-Control-Allow-Origin behavior on cross-origin requests
- Subresource Integrity (SRI) presence check on externally hosted script tags

Findings were scored using an aggregate header-hardening rubric (informed by common public scoring frameworks such as securityheaders.com's methodology) to produce a single comparable grade, alongside the itemized per-control breakdown in the report.

7. Risk Scoring Methodology

Each finding was scored using a two-factor model — likelihood and impact — rather than a single subjective severity label. The criteria below were applied consistently across all findings:

Severity	Likelihood Criteria	Impact Criteria
High	Exploitable by an unauthenticated or low-privilege actor with no special conditions	Directly undermines the platform's core trust/integrity guarantee (e.g., identity claims surfaced to consumers)
Medium	Requires an additional precondition (e.g., targeted timing, absence of monitoring)	Degrades a supporting control without immediately compromising the core trust guarantee
Low	Requires significant additional conditions or provides limited standalone value to an attacker	Reduces defense-in-depth; primarily relevant in combination with other findings

Impact was assessed specifically against FABA's business model (a professional-verification and referral platform), not generic CVSS-style technical impact alone. A finding that would be Low on a typical content site (e.g., unverified user-generated listings) was scored higher here because unverified professional listings strike directly at the platform's core value proposition.

8. Evidence Standard and Limitations

8.1 Evidence Standard

Every finding in the report reflects a directly observed result from a specific, repeatable test action — not an inference or assumption. Where a plausible risk existed but could not be confirmed through available testing (e.g., backend sanitization, internal approval workflows), the report states that explicitly rather than asserting a vulnerability.

8.2 Limitations

- No source code or backend system access — all findings are behavior observed from outside the application boundary
- No authenticated testing beyond a single low-privilege account — administrative and elevated-privilege workflows were not assessed
- No automated scanning tooling used against production — findings are the result of manual testing only, which trades some coverage for safety on a live platform
- Time-boxed engagement — findings represent the state of the platform as observed during the assessment window and may not reflect subsequent changes

9. Public-Release Sanitization Methodology

Before publishing the companion report (v1.2), every finding was reviewed against a simple test: could this description be used, as written, to reproduce the observation against the live platform? If yes, it was generalized. Specifically redacted or generalized categories:

- Individually identifying information not already independently public
- Exact test values, payloads, or placeholder data used during testing
- Precise technical parameters of any workflow with security relevance (e.g., verification code format/length)

- Any detail that narrows a finding from a general weakness class down to a specific, copy-pasteable reproduction step

The severity ratings, risk methodology, and recommendations were left intact, since they represent analysis and judgment rather than reproducible technical detail.